DATA ITEM DESCRIPTION
Title: SECURITY CONFIGURATION COMPLIANCE REPORT

Number: DI-SCRE-82454
AMSC Number: 10506
DTIC Applicable: No
Preparing Activity: PT
Applicable Forms:

Approval Date: 20240916
Limitation: None
GIDEP Applicable: No
Project Number: SCRE-2024-002

Use/relationship: This Data Item Description (DID) defines the format, content, and intended use of the Security Configuration Compliance Report (SCCR) for Foreign Military Sales (FMS) programs that do not contain Critical Program Information. The SCCR is a key deliverable at the Preliminary Design Review and approved prior to Acceptance Testing. This is specifically for standalone training systems. Standalone training systems include those operating on intranets and closed networks. This DID demonstrates how the contractor has implemented cybersecurity controls to meet applicable security requirements. The SCCR facilitates a clear overview and verification of these implemented controls, ensuring the project adheres to established security best practices through written documentation and relevant system reports.

Requirements:

1. Reference Documents: None

2. Format: The Security Configuration Compliance Report (SCCR) shall be delivered in a common readable format such as Microsoft Excel or Word. Supplemental evidence for each control, such as screenshots, system scans, and configuration reports, are acceptable. Contractor format is acceptable for the SCCR.

3. Content: The SCCR shall include each of the following sections:

3.1. Section 1. System Security Configuration Management

3.1.1. LEAST FUNCTIONALITY: Describe how the principle of least functionality has been implemented on the system and associated configurations. This includes:

3.1.1.1. SOFTWARE: Detail how non-essential software applications have been removed or disabled. Acceptable supporting evidence: screenshots of relevant system configuration settings or software inventory lists.

3.1.1.2. SERVICES: Describe how all non-essential system services have been disabled or removed. For any essential services that remain enabled, document the rationale for their continued operation.

3.1.1.3. FEATURES: List the system features that are enabled or required for system operation. State whether all other features have been disabled or removed. Examples of features include but are not limited to: Wi-Fi, Bluetooth™ camera, microphone, etc.

Source: https://assist.dla.mil -- Downloaded: 20260-26T11:03Z
Check the source to verify that this is the current version before use.

3.1.1.4. USER ACCOUNTS: Describe how user accounts (e.g. administrator, instructor, student) are created with the principle of least privilege, granting only minimal access required for assigned roles. Additionally, describe how administrator accounts are configured to prevent internet access.

3.1.1.5. PORTS AND PROTOCOLS: Provide a table of what ports are enabled on the system. Each entry in the table includes: the port number, the protocol Transmission Control Protocol/User Datagram Protocol (TCP/UDP/Both), service name, and purpose. The goal of this paragraph is to ensure only necessary ports are opened on the system.

3.1.2. SERVER CONFIGURATION: Describe how the server is configured and hardened. Include at a minimum: the server make, model, firmware version, IP filtering rules, disabling of unused services and ports, logging and auditing configuration (e.g. what events are logged, log retention period), and password complexity.

3.1.2.1. SYSTEM AUDITING AND MONITORING: Describe what mechanisms are in place for monitoring network activities and what is being monitored such as access attempts, and whether designated personnel are notified of unauthorized attempts.

3.1.2.2. TOMBSTONE LIFETIME: Specify the current tombstone lifetime setting (in calendar days) to accommodate anticipated shipping delays and prevent potential data loss. Tombstone lifetime determines how long deleted objects are retained in Active Directory, which allows for data recovery and ensures data consistency during synchronization across domain controllers. Furthermore, the tombstone lifetime setting impacts the time a system can remain powered down in an inoperative state before all account authorizations are permanently deleted, necessitating system reinstallation or reconfiguration. Provide the expected date for system assembly and state the intended adjustment to the tombstone lifetime (in calendar days) after the system is assembled. Consider potential impacts on system performance, data availability, and the length of time the system can be in an inoperative state when determining the necessary tombstone lifetime setting.

3.2. Section 2. Data Protection

3.2.1. DATA AT REST: Describe the encryption tools and methods used to protect data at rest on hard drives. Specify whether all hard drives or only specific ones (e.g., system drive) are encrypted. State whether the Trusted Platform Module (TPM) is enabled and used for data encryption. Briefly describe what the encryption recovery process is.

3.2.2. DATA IN TRANSIT: Describe the measures implemented to protect data while it is being transferred between system components or transmitted over external networks.

3.3. Section 3. Access Control

3.3.1. ACCESS ENFORCEMENT: Describe how Role-Based Access Control (RBAC) is implemented to manage user access to the system. This description includes: The mechanism

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.

used to enforce RBAC (e.g., automated system, manual processes). A list of user roles defined within the RBAC system. For each user role, describe the access permissions granted (e.g., data access, functionality restrictions).

3.3.2. SEPARATION OF DUTIES: Building upon the RBAC implementation described in Section 3.3.1, further describe the controls in place to enforce separation of duties. Describe how no single user account has permissions that could be misused for unauthorized activities.

3.3.3. LEAST PRIVILEGE: Describe how the principle of least privilege has been implemented to grant user accounts the minimum access required to perform their assigned duties. Address user roles and account permissions.

3.3.4. LOGIN ATTEMPTS: Describe how the Operating System (OS) has been configured to limit unsuccessful login attempts. This description includes: The specific method used to configure login attempt limits within the OS (e.g., group policy for Active Directory, local security settings for standalone systems). The predefined number of consecutive unsuccessful login attempts allowed before the account is locked. The duration for which the account is to be locked.

3.3.5. SESSION LOCK: Describe how the OS has been configured to automatically lock a user's session after a period of inactivity. This description includes: The specific method used to configure session timeouts (inactivity thresholds) within the OS (e.g., group policy for Active Directory, local security settings for standalone systems). The time period for session inactivity after which user sessions are be automatically locked. List timeouts by account type if applicable (e.g., shorter timeouts for administrator and longer for instructor accounts).

3.3.6. SESSION TERMINATION: Describe how the OS has been configured to automatically terminate a user's session after a period of inactivity, following a session lock. This description includes: Whether the OS automatically terminates sessions after a lock. The additional time period of inactivity after a session lock that triggers automatic session termination.

3.4. Section 4. Identity and Authentication

3.4.1. PASSWORD MANAGEMENT: Describe in detail the password configuration complexity to enforce strong password creation practices. This description includes: The minimum password length requirement. The required character types for passwords (e.g., uppercase letters, lowercase letters, numbers, symbols). Password history requirements (e.g., details for when a password can be reused). A description of how password filters are used to prevent weak passwords (e.g., disallowing dictionary words, common keyboard patterns). Whether the operating system's built-in password complexity filter has been enabled.

3.4.2. SECURE USER AUTHENTICATION: Describe in detail the supported Multi-Factor Authentication (MFA) methods on the system (e.g. fingerprint scanner, one time password). Description of the Public Key Infrastructure solution implemented, including the type of digital certificates used and the Certificate Authority (CA) employed. Reference the rationale for each (e.g. FMS customer requirements).

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.

3.5. Section 5. Security and Information integrity

3.5.1. MALICIOUS CODE PROTECTION: Describe the anti-virus software used to protect the system from malware threats. Include details about: Software name, version, when it was last updated, and how it is configured.

3.6. Section 6. System Assurance and Maintenance

3.6.1. UNSUPPORTED SOFTWARE: Describe any software identified as End-of-Life (EOL) or End-of-Support (EOS) on the system. Include: listing what software is EOL/EOS, the rationale or requirement of using the EOL/EOS software, an assessment on the feasibility of upgrading or replacing the EOL/EOS software, a description of mitigations implemented to minimize risks associated with the EOL/EOS software. An example of mitigations would be implementation of a vendor's applicable security baseline or best practice guides.

3.7. Appendix: Other Technical Documents

3.7.1. Appendix A.

3.7.1.1. CYBERSECURITY ADMINISTRATOR GUIDE (CSAG): The Cybersecurity Administrator Guide (CSAG) is an essential document that provides a comprehensive set of step-by-step instructions and procedures for system administrators responsible for the secure operation of a system. The CSAG should include the following sections and requirements:

1. System Overview: A summary of the system, its purpose, and intended use.
2. System Security Configuration: A detailed description of how the server is configured and hardened, adhering to relevant government regulations. This section should include the following:
    - Server make and model
    - Operating system version and patch status
    - Firmware version
    - IP filtering rules
    - Disabling of unused services and ports
    - Logging and auditing configuration (e.g., events logged, log retention period)
    - Password complexity and identity and access management details
    - Antivirus/anti-malware software and updates
3. Access Control: Detailed descriptions of the system's access control methods, such as role-based access control (RBAC), authentication, and authorization mechanisms.
4. Account Management: Instructions for managing user and administrator accounts, including account creation, modification, and deletion, as well as password policies and procedures.
5. Incident Response: Procedures for responding to security incidents, including detection, containment, eradication, recovery, and lessons learned.

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.

6. Anti-Malware Configuration: Details on the installation, configuration, and ongoing management of anti-malware software, such as antivirus, anti-spyware, and other security tools.
7. Encryption Recovery Procedures: Instructions for managing encryption keys and passwords, and procedures for recovering encrypted data when necessary.
8. Backup and Recovery procedures: Detailed processes for creating system backups, defining backup schedule, retention policy, and storage locations, as well as recovery procedures for forgotten administrator passwords.
9. Software Supply Chain Risk Management: Any information about the install media used for software/firmware installs or updates, such as batch, serial, date, and URL of download or control information. For physical media, specify the source (i.e., vendor(s) and/or websites), type, and manufacturer for effective software supply chain risk management.

3.7.2. Appendix B.

3.7.2.1. SYSTEM SECURITY PLAN (SSP): The System Security Plan (SSP) is a comprehensive document detailing the security controls implemented to protect the system. Appendix B contains a copy of the SSP, tailored to meet the specific security requirements of the FMS Customer. The SSP shall address the following minimum control areas: System Description, Security Concept of Operations (CONOPS), System Hardware Components, System Software Components, Ports, Protocols, and Services (PPS), Network Diagram, Information Flow Diagram (if different), Access Control, Account Management, Separation of Duties, Least Privilege, Unsuccessful Logon Attempts, Session Lock, Session Termination, Audit and Accountability, Configuration Management, Contingency Planning, Identification and Authentication, Incident Response, Risk Assessment, System and Communications Protection, System and Information Integrity, Acronym List. The SSP shall be signed by the company Information System Security Manager (ISSM).

3.7.3. Appendix C.

3.7.3.1. PLAN OF ACTION AND MILESTONES (POA&M): The Plan of Action and Milestones (POA&M) is a living document that tracks the progress of addressing Information Assurance (IA) control deficiencies and non-compliant vulnerability findings identified in the system's security assessments. Appendix C contains a copy of the company's POA&M. The POA&M details the following: Not Applicable (N/A) IA Controls with justification why it’s N/A, All Non-Compliant IA Controls with description, remediation steps, and target dates, and all non-compliant vulnerability findings as identified in the vulnerability Scans, Security Technical Implementation Guides (STIGs), System Requirements Guides (SRGs), and Security Content Automation Protocol (SCAP) Benchmarks.

3.7.4. Appendix D.

3.7.4.1. CONTINUITY OF OPERATION PLAN (COOP): The Continuity of Operations Plan (COOP) outlines the procedures and resources for maintaining essential business functions

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.

during and after a disaster or other disruptive event. Appendix D contains a copy of the company's COOP. At a minimum, the COOP addresses the following key elements:

3.7.4.1.1. Essential Functions: Identification of the critical functions that must be maintained during a disruption.

3.7.4.1.2. Personnel Roles and Responsibilities: Assignment of roles and responsibilities for personnel involved in COOP execution.

3.7.4.1.3. Communications Plan: Strategies for maintaining communication with employees, customers, and other stakeholders during a disruption.

3.7.4.1.4. Data Backup and Recovery: Procedures for backing up critical data and restoring it in the event of a loss.

3.7.4.1.5. Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs): Definition of expected timeframes for restoring critical functions and data after a disruption.

3.7.5. Appendix E.

3.7.5.1. HARDWARE, SOFTWARE, AND DIAGRAM: Provide a copy of the system's hardware list, software list, and architecture diagram within Appendix E of the SCCR.

3.7.5.1.1. The hardware list shall be in the form of a table. The list shall at a minimum contain: Device name, manufacturer, model number, firmware version, and purpose.

3.7.5.1.2. The software list shall be done in the form of a table. The list shall at a minimum contain: software name, acronym, version, and intended function.

3.7.5.1.3. The system diagram depicts the system architecture. Acceptable formats include embedded image or separate Microsoft Visio™ file. The diagram at a minimum contains: A solid black line delineating the system boundary, a legend explaining the line connections used, connections between devices, all devices listed on the hardware list to include applicable information listed in 3.7.5.1.1., the device IP address, and a separate table listing the open TCP/UDP ports and services.

3.7.6. Appendix F.

3.7.6.1. SYSTEM HARDENING: This appendix describes the system hardening process used to establish a secure baseline configuration. Include the following principles:

3.7.6.1.1. Security Baselines: List applicable STIGs, SRGs, and/or SCAP Benchmarks identified and used as the foundation for system configuration.

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.

3.7.6.1.2. Configuration Compliance: Describe how the system is configured to comply with requirements outlined in these baselines. Describe and address any deviations from these baselines (non-compliant findings).

3.7.6.1.3. Non-compliant Findings and Mitigation: Non-compliant findings identified during vulnerability scans, STIG assessments, SRG reviews, or SCAP benchmark evaluations are documented in the POA&M (refer to Appendix C). Include the following details within the POA&M and STIG remarks section: The identified issue. The associated mitigation strategy (administrative, physical, or technical). The target completion date for implementing the mitigation strategy.

3.7.6.2. STIG, SRG, and SCAP Benchmark Artifacts: STIG, SRG, and SCAP Benchmark artifacts (e.g., checklists, reports) are in a readable format, or the original ".ckl" file. These artifacts are secured according to the system's classification level and protected accordingly.

3.7.6.2.1. STIG, SRG, and SCAP Benchmark Updates: STIGs, SRGs, and SCAP Benchmarks are updated periodically. State when the most recent update was applied.

3.7.7. Appendix G.

3.7.7.1. SYSTEM SCANNER: Provide details about the automated system scanning software used to identify security vulnerabilities and configuration weaknesses. Include details such as: software name, type (Government-Off-The-Shelf (GOTS) or Commercial-Off-The-Shelf (COTS)), software version.

3.7.7.1.1. Scan Results: A report summarizing the scan results in a clear and readable format (e.g., spreadsheet, table). At a minimum include: Identified vulnerabilities with severity levels. Recommended remediation actions. Scanned ports ("0-65535" or "all"). A full list of system software. Document non-compliant findings in the system POA&M (refer to Appendix C).

3.7.7.1.2. Vulnerability scans are handled and transmitted in accordance with the system's classification level. Vulnerability reports are provided in a commonly readable format. If ACAS is used, the original ".nessus" file format is acceptable. Vulnerability scans and associated software are to be protected according to the system's classification.

3.7.8. Appendix H.

3.7.8.1. MISCELLANEOUS: Appendix H contains additional requirements not specified in any of the above sections of the SCCR.

End of DI-SCRE-82454

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.